📌 令和3年秋期 応用情報技術者試験 午後問1【情報セキュリティ】小南解析

一、整体背景与办公安全架构梳理

1. 办公区警戒等级与区域划分（図 1）

A社（日用杂货电商）因业务扩大管理大量个人信息，为强化安全而重新评估办公区的**物理安全措施**。办公区按警戒等级划分为 4 个 Zone：

警戒区域	覆盖空间	入退管理限制
第1ゾーン	受付エリア（前台）、打合せスペース（洽谈区）	无入室限制（外来人员及员工均可进入）
第2ゾーン	執務エリア（办公区）、会議室、ロッカー室（更衣室）	全体员工持有 IC 卡均可解锁进入
第3ゾーン	資料保管室	仅限获得授权的特定员工解锁进入
第4ゾーン	サーバ室（机房，警戒等级最高）	仅限获得最高授权的特定员工解锁进入

2. 核心技术原理与安全标准

- **非接触式 IC 卡（社員カード）原理**：卡内内置**天线线圈（アンテナコイル）**，当靠近读卡器（CR）时，利用 CR 发出的电磁波（電磁波）通过电磁感应产生电流，供电给 IC 芯片运行并完成无线通信。
- **多功能一体机（複合機）安全标准**：获得 **CC（Common Criteria，ISO/IEC 15408）** 认证，这是评估 IT 产品及系统安全设计的国际标准评估规格。

3. 六大物理安全隐患与改善对策一览（表 1）

序号	隐患问题	导致风险	改善对策 / 安全手段

1	尾随入室（共連れ）	未授权人员潜入高警戒区	出口加装 CR，引入**反潜回（アンチパスバック）**机制
2	访客单独行动	数据偷窥、设备非法篡改	陪同制 + 机房安装**监控摄像头记录行为**
3	打印纸张遗留在复合机	个人信息/机密泄露	刷卡认证的**按需打印（オンデマンド印刷）**
4	带私物背包进入办公区	私自带入危险物或违规设备	禁止私自带包，统一发放**透明包（中が透けて見える鞄）**
5	桌面散落纸质文件/NPC	敏感信息被偷窥	贯彻**桌面清理（クリアデスク）**政策
6	电脑登录状态下离席	账号被他人冒用/非法操作	贯彻**屏幕清理/锁屏（クリアスクリーン）**政策

🔍 二、逐题深度解析

設問 1：IC 卡工作原理与安全评价规格（a, b, c）

> 💡 **问题**：从解答群中选择填入 [a]、[b]、[c] 处最合适的选项。

- **参考答案**：
  - **a**：`カ`（アンテナコイル）
  - **b**：`ク`（電磁波）
  - **c**：`ア`（CC: Common Criteria）
- **逻辑拆解**：
  - **[a] 与 [b]（非接触 IC 卡工作机制）**：
    - 非接触式 IC 卡内部没有内置电池。当卡片靠近读卡器（CR）时，读卡器发出的 **电磁波（ク）** 穿过卡片内部的 **天线线圈（カ）**，产生电磁感应（感应电动势），将接收到的能量转换为电能，从而驱动 IC 芯片与 CR 进行无线通信。
  - **[c]（IT 安全评价规格）**：
    - 题干明确说明该规格为“评估 IT 设备与 IT 系统安全设计的标准”。符合此定义的评估标准是 **CC（Common Criteria，ISO/IEC 15408）**，故选 `ア`。

- *干扰项排除*：`ISMS` 为安全管理体系认证标准；`JIS Q 15001` 为个人信息保护（Pマーク）管理体系标准。

設問 2：终端离席安全策略（クリアスクリーン）

> 💡 **问题**：针对表 1 中项番 5（桌面放置文件）的对策称为 Clear Desk（クリアデスク），那么针对项番 6（登录状态下离席）的对策称为什么？（10字以内）

- **参考答案**：`クリアスクリーン`（8文字）
- **逻辑拆解**：
  1. **安全隐患**：员工离开座位时若未锁定电脑，任何经过的人都可以偷窥屏幕信息或冒用其身份进行非法操作。
  2. **标准规范（JIS Q 27002 / ISO 27002）**：
     - **Clear Desk（クリアデスク）**：离席或下班时，将桌面上的纸质敏感文件、存储介质锁入柜中。
     - **Clear Screen（クリアスクリーン）**：离席时强制注销或使用带密码的屏幕/键盘锁，确保屏幕无机密信息残留。

設問 3：物理安全与物理入退控制

(1) 下划线①：反潜回（アンチパスバック）机制拒绝对刷卡解锁的条件

> 💡 **问题**：下划线①中，即便持卡人持有效卡刷卡，在什么情况下反潜回机制会判定为异常并拒绝解锁？（30字以内）

- **参考答案**：`入室状態となっている人が再度入室しようとした場合`（24文字）
- **逻辑拆解**：
  1. **反潜回（Anti-passback）原理**：系统严格记录每个 ID 的“入室”和“退室”状态，要求“入”与“出”必须交替成对出现。
  2. **场景推导**：
     - 题干前半句已经说明了退室限制：“未处于入室状态的人试图退室时不予解锁（如跟着别人尾随进入，系统无入室记录）”。

- 题干下划线①对应的是入室限制：如果某人的记录显示“当前处于入室状态”（例如他刷卡进门后把卡借给身后的人，或者自己尾随别人出来后又想刷卡进去），系统会发现“连刷两次入门”，从而判定为尾随或借卡异常，拒绝解锁。

(2) 下划线②：第 4 ゾーン（机房）针对访客事后追溯的设备措施

> 💡 **问题**：对于无法全程陪同的机房外来维护人员，如何在事后确认其行为？请给出具体的设备对策。（25字以内）

- **参考答案**：監視カメラを設置して来訪者の行動を記録する （21文字）
- **逻辑拆解**：
  1. **限定条件**：
     - 针对服务器机房（第 4 ゾーン）；
     - 担当员工无法全程陪同（如外部厂商进行例行维护）；
     - 独立于服务器控制台操作日志（技术对策）之外；
     - 需满足“能够事后确认行动”的设备。
  2. **对策提取**：安装监控摄像头（監視カメラ）对机房内访客的操作与移动全程录像，既能形成物理心理威慑，又能在出事后进行审查追溯。

(3) 下划线③：按需打印（オンデマンド印刷）降低打印物放置风险的原因

> 💡 **问题**：为什么按需打印功能能够有效减少打印纸张在复合机旁的遗留放置？（30字以内）

- **参考答案**：複合機の側に行かないと用紙への印刷ができないから （24文字）
- **逻辑拆解**：
  1. **传统打印痛点**：员工在座位上点击“打印”后，纸张立刻在复合机吐出；若员工被电话打断或忘记去取，敏感文件就会长期裸露遗留在复合机上。
  2. **按需打印（On-demand Printing）流程**：电脑发送命令 → 任务暂存服务器/复合机队列 → **员工亲自走到复合机前** → **刷卡/输入密码认证** → 复合机现场开始吐纸 → 员工当场拿走文件。

3. **核心原因**：只有当本人亲自来到复合机旁完成认证时，纸张才会打出来，从源头上消除了“打印出纸后无人领取”的现象。

(4) 借用背包特征（d）与防范的非法行为

> 💡 **问题**：填入 [d] 处借用背包的特征（10字以内），并说明除了防止带入禁带私物外，还能防范什么非法行为？（15字以内）

- **参考答案**：
  - **d**：`中が透けて見える`（8文字）
  - **行為**：`秘密書類の持出し`（8文字）
- **逻辑拆解**：
  - **[d]（背包特征）**：
    - 允许员工带私物进入办公区，但禁止使用私有不透明背包。替代方案是公司统一发放**透明包/透光包（中が透けて見える鞄 / 透明な鞄）**，安全人员或同行员工一眼就能看到包内物品。
  - **行為（防止的不正行为）**：
    - 透明包不仅能“防止私自将外部危险物/违规介质带进来（入）”，更重要的是能通过可视检查，**防止员工将办公区的纸质机密文件或资产私自藏在包里带出去（出）**，即防止**秘密書類の持出し（机密文件的带出）**。

🚀 三、核心考点速查（AP 物理安全与管理策略）

考察维度	考点核心	原理要点
物理防割	ゾーン管理 (Zone Control)	按警戒等级对办公区分区（Zone 1~4），配以不同权限的入退卡及监控设备。
入退控制	アンチパスバック (Anti-passback)	严格校验“一进一出”逻辑，防止借卡解锁与尾随（共連れ）入室。
终端安全	クリアデスク / クリアスクリーン	离席锁屏（Clear Screen）与桌面无纸化/锁柜（Clear Desk）是 ISO 27002 的基本要求。
输出安全	オンデマンド印刷 (On-demand)	刷卡认证后才现场打印，防止敏感纸质文件在打印机托盘遗留泄密。

物品管控	透明鞄 (Clear Bag) 政策	强化办公区进出物料的可视化审查，双向防范非法带入与机密带出。